random token into the URI path or query parameters. More secure variants encode the token into the fragment or userinfo components but come at a cost of increased complexity for clients.

· Macaroons allow anybody to restrict a capability by appending caveats that can be cryptographically verified and enforced by an API. Contextual caveats can be appended just before a macaroon is used to secure a token against misuse.

· First-party caveats encode simple conditions that can be checked locally by an API, such as restricted the time of day at which a token can be used. Third-party caveats require the client to obtain a discharge macaroon from an external service proving that it satisfies a condition, such as that the user is an employee of a certain company or is over 18.

ANSWERS TO EXERCISES

1. a, e, f, or g are all acceptable places to encode the token. The others are likely to interfere with the functioning of the URI.
2. c, d, e.
3. b and e would prevent tokens filling up the database. Using a more scalable database is likely to just delay this (and increase your costs).
4. e - without returning links a client has no way to create URIs to other resources.
5. d - if the server redirects the browser will copy the fragment to the new URL unless a new one is specified.